



API Security Assessment Report

<https://api.example.com>

REPORT ID	example-scan
GENERATED	2026-09-13T00:00:00Z
SCAN STATUS	COMPLETED
ASSESSMENT PROFILE	STANDARD

CONFIDENTIAL - AUTHORIZED SECURITY TESTING

Automated testing does not guarantee complete vulnerability detection.

Executive Summary

This report presents the results of an automated security assessment of <https://api.example.com>. Findings require manual validation before remediation or exploitation decisions are made.

3	1	66.7%	MEDIUM
ENDPOINTS	FINDINGS	COVERAGE	OVERALL RISK

Severity Distribution

CRITICAL	HIGH	MEDIUM	LOW	INFO
0	0	1	0	0

Scope and Coverage

FIELD	VALUE
Target	https://api.example.com
Started	2026-09-12T23:59:17.900000Z
Finished	2026-09-13T00:00:00Z
Duration	42.1 seconds
Endpoints tested	2 of 3
Skipped / not tested	1 / 0

An untested endpoint is not evidence that the endpoint is not vulnerable.

Findings Overview

ID	SEVERITY	RISK	FINDING	AFFECTED ENDPOINT
F-001	MEDIUM	5.5	Operation accessible without declared authentication	GET /private

Detailed Findings

Every scanner finding is listed below. Full machine-readable evidence is available in the accompanying technical JSON report.

F-001 Operation accessible without declared authentication			MEDIUM
Risk score	5.5	Confidence	HIGH
Affected	GET /private	Parameter	Not specified
Classification	missing-authentication API2:2023 Broken Authentication CWE-306	Status	OPEN
Detected by	custom, zap		

Description

The protected operation returned the same data without credentials.

Impact

Unauthenticated callers may retrieve restricted data.

Evidence

```
[
  {
    "engine": "custom",
    "request": {
      "method": "GET",
      "url": "https://api.example.com/private"
    },
    "response": {
      "status_code": 200,
      "body": "Restricted account data returned."
    },
    "detail": "The response was equivalent with and without authentication."
  }
]
```

Recommended Remediation

Enforce authentication and authorization server-side for this operation.

References

<https://owasp.org/API-Security/>

Appendix A - Engine and Coverage Detail

ENGINE	STATUS	REQUESTS	NOTES
custom	COMPLETED	3	
zap	COMPLETED	12	

Assessment Limitations

Automated scanners may produce false positives and false negatives. Business logic, authorization boundaries, authenticated workflows, and environment-specific controls require manual pentester validation. No finding should be treated as confirmed solely because it appears in this report.